

ABHI SHARMA

Indore, India | +91 9424483008 | abhis9102@gmail.com | [linkedin.com/in/a13h1](https://www.linkedin.com/in/a13h1)
hackerone.com/root_a13h1 | medium.com/@a13h1 | abhis9102.github.io/a13h1

PROFESSIONAL SUMMARY

Offensive Security and Application Security Engineer with **4+** years of experience across **AppSec**, penetration testing, and vulnerability research. Currently leading **AppSec** and **VAPT** at Flexton Inc., conducting multi-tenant SaaS assessments and embedding automated CI/CD guardrails (**SAST**, SCA, secret scanning, **DAST**) into developer pipelines. Strong foundation in agentic **AI** systems, protocol security (**MCP**, A2A), and frameworks (LangChain, ReAct), demonstrated through the development of **Hackbot** and **AI**-assisted defense tooling. Active security researcher with **4,000+** reputation and **100+** resolved reports on HackerOne, recognized on the **Hall of Fame** of X, Netflix, and Tencent.

TECHNICAL SKILLS

AI Agent Security: **MCP** Servers, Tool Execution Workflows, Agent Skills, Hooks, Plugins, Extensions, Coding Agents (Cursor, Claude Code), Protocol Security (**MCP**, A2A), Agent Frameworks (LangChain, ReAct), Prompt Injection Research, In-line Critic and Guardrail Pipelines

AppSec and DevSecOps: Secure CI/CD Pipelines (GitHub Actions), **SAST** (**Semgrep**, **CodeQL**), **DAST** (**Burp Suite Pro**, **OWASP ZAP**), SCA (Dependency Scanning), Secret Scanning (Gitleaks, TruffleHog), SBOM (Syft), Pre-commit Hooks, PR Quality Gates, SARIF Triage, **Secure SDLC**

Offensive Security and PenTesting: Web Application, **REST** and **GraphQL API** Security, **Broken Access Control** (**IDOR**/**BOLA**/**BFLA**), Tenant Isolation, Auth/AuthZ Flaws, Business Logic Assessment, **Threat Modeling** (**STRIDE**), Nuclei, SQLMap, Katana, httpx, ffuf, **Nessus**, Nmap, Metasploit, **CVSS**

Cloud and Infrastructure: AWS (**IAM** Policy, **Privilege Escalation** Paths, S3 Exposure, **SSRF**-to-**IMDS**, EC2, Lambda, VPC, CloudWatch), Linux, Active Directory, Zero-Trust Access Models

Programming and Scripting: Python, JavaScript, Bash, Java, with familiarity in TypeScript and Go for engineering collaboration

PROFESSIONAL EXPERIENCE

Security Operations Engineer

FLEXTON INC.

Oct 2022 – Present

- Lead the **AppSec** and **penetration testing team** across full engagement lifecycles, defining testing methodology, mentoring researchers, and reviewing technical assessments for accuracy, severity, and evidence quality prior to client delivery.
- Embedded automated **AppSec** guardrails into CI/CD pipelines (GitHub Actions), integrating diff-aware **SAST** (**Semgrep**), SCA dependency scanning, SBOM generation (Syft), and secret scanning (Gitleaks, TruffleHog) with PR quality gates to block high/critical flaws before release.
- Conduct **STRIDE threat modeling** across applications and **APIs** to identify attack vectors, trust-boundary violations, and authentication/authorization weaknesses prior to feature rollout.
- Analyze AWS security configurations (EC2, S3, VPC, **IAM**, Lambda, RDS, CloudWatch) for **IAM privilege escalation**, storage exposure, role assumption, and **SSRF**-to-**IMDS** attack paths.
- Delivered penetration testing across enterprise web applications, **REST/GraphQL APIs**, and AWS cloud environments for clients in **fintech**, automotive/dealer marketplaces, telehealth, **workflow**-automation and enterprise SaaS, creative-writing communities, ministry/church management, scientific computing, monitoring and observability, HR-tech, scheduling, payroll, CDN/edge infrastructure, **fintech**/subscription-billing, and cloud communications (UCaaS).
- Develop **end-to-end** proof-of-concepts (PoCs) to validate complex attack paths and demonstrate practical exploitability across **Broken Access Control**, **IDOR/BOLA**, **SQLi**, **XSS**, **SSRF**, **CSRF**, **privilege escalation**, and business logic flaws.
- Drive developer-centric **AppSec workflows** through **Semgrep secure code** reviews, tracing findings to source code to confirm exploitability, and correlating **SAST/SCA** with **DAST** results to triage SARIF reports and eliminate false positives.
- Deploy proprietary automation tooling, including an **AI**-native secret scanner (LLM-based noise filtering) and reconnaissance pipelines, to scale attack-surface discovery and credential triage across client engagements.
- Authored developer-first secure coding guidelines and proactive architectural guardrails for recurring vulnerability classes (**XSS**, **IDOR**, business logic, auth flaws), reducing recurrence in downstream testing by **90%**.
- Conduct **security risk assessments** and map findings to **PCI DSS**, **ISO 27001**, **SOC 2**, and **OWASP ASVS** compliance controls, delivering prioritized remediation roadmaps.
- Leverage **AI** tooling to rapidly generate attack hypotheses and novel test scenarios against complex application features during manual testing, reducing average **time-to-detect** for vulnerabilities by **70%**.

- Conducted comprehensive application security assessments of a **zero-trust** document verification and storage platform handling sensitive personal and employment records.
- Identified and reported **38** confirmed vulnerabilities, including 13 **XSS**, 10 **Broken Access Control**, 7 **IDOR**, 3 **SSRF** via PDF rendering, 3 **privilege escalation**, and 2 HTML injection flaws.
- Combined **Semgrep SAST** with dynamic testing in **Burp Suite Professional** to trace and validate vulnerability exploitability across core **workflows**.
- Collaborated directly with engineering teams across multiple remediation cycles, retesting and verifying all fixes through sign-off, earning a formal recommendation from the **CTO**.

PROJECTS

Hackbot (Agentic Vulnerability Research Framework): Built a Claude-powered autonomous pentesting agent implementing a ReAct loop (Reason → Execute → Observe → Reflect → Critic) with tool execution **workflows**, modular skills, and **MCP** servers. Features an automated critic module that enforces evidence-chain validation, blocking unconfirmed findings (e.g., rejecting **IDOR** without cross-account proof, **SQLi** without timing/error proof, **SSRF** without OOB interaction). Maintains 25 methodology modules covering vulnerability classes from **IDOR/BOLA** and **SSRF** to **GraphQL** authorization, deserialization, race conditions, and **AI/agent** security (prompt injection, **MCP** and A2A trust boundaries, tool abuse). Applied against live targets and open-source repositories, producing a confirmed, **CVSS**-scored cross-tenant **BOLA** finding on a production SaaS **API**.

AI-Native Secret-Scanning Tool: Designed and built a custom, standalone security tool (proprietary detection logic, not an OSS wrapper) to identify hardcoded secrets, credentials, and leaked configuration in public client-facing assets (JS bundles, **API** responses). Incorporates an LLM within the detection pipeline to classify ambiguous candidates as genuine secrets versus noise, cutting false positives before findings reach triage.

Automated Reconnaissance Framework: Designed and maintained an **end-to-end** recon pipeline integrating open-source tools for subdomain enumeration, HTTP probing, JS analysis, endpoint discovery, technology fingerprinting, and attack-surface mapping.

ACHIEVEMENTS AND RECOGNITION

- **HackerOne:** **4,000+** reputation, **100+** valid vulnerability reports resolved across enterprise programs.
- **Hall of Fame:** Listed on security acknowledgment pages of X (formerly Twitter), Netflix, and Tencent for responsible disclosures.
- **Technical Research:** Published in-depth technical writeups on Medium and InfoSec Write-ups on race conditions, **API privilege escalation**, and business logic flaws (e.g., "**\$2,150** Critical Authorization Bypass: Viewer to Admin via **API**").
- **Community:** Volunteer at BSides Goa.

EDUCATION AND CERTIFICATIONS

B.Tech., Computer Science and Engineering | Sri Aurobindo Institute of Technology, Indore (2022)

Certifications: Offensive Security Certified Professional (OSCP), in progress

Languages: English (Professional), Hindi (Native)